# Digital Forensic Investigation Report: Project Vantage

**Report ID:** 2026-HTB-SHERLOCK-VANTAGE

**Investigator:** Risma Fareedh

**Date of Investigation:** Mar 06, 2026

**Subject:** OpenStack Cloud Breach, Data Exfiltration and Persistence

## 1. Executive Summary

On July 1, 2025, a security incident was identified involving the unauthorized access of the cloud.vantage.tech subdomain. An external adversary successfully utilized automated fuzzing tools to discover the cloud dashboard, bypassed authentication, and compromised OpenStack API credentials. The attacker exfiltrated multiple PII (Personally Identifiable Information) records and established a secondary administrative account for persistence. This report details the timeline, methodology, and remediation strategies.

## 2. Environment Overview

This environment overview describes a foundational OpenStack cloud computing platform deployment designed to provide Infrastructure-as-a-Service (IaaS). It uses a modular architecture where distinct services manage compute, storage, identity, and user interface components to create, manage, and scale virtualized resources. Here is an explanation of each component in your environment:

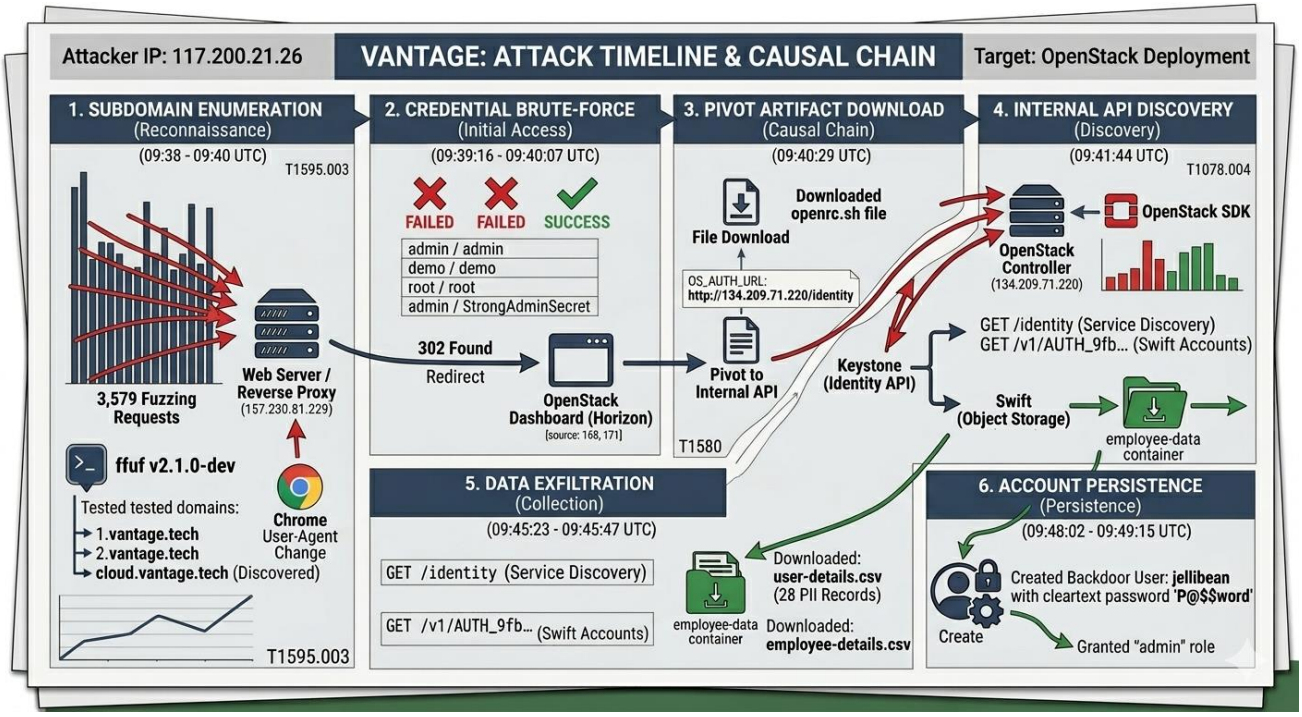
- **Keystone (Identity):** Central authentication and API token management.
- **Swift (Object Storage):** Distributed storage for unstructured data and sensitive backups.
- **Horizon (Dashboard):** The web-based GUI used for the initial point of entry.
- **Nova & Glance:** Compute and Image services used for infrastructure enumeration.

## 3. Incident Timeline (UTC)

| Timestamp | Service | Event / Action Description |
|---|---|---|
| **09:35:12** | Web Server | Reconnaissance via ffuf v2.1.0-dev; identification of cloud.vantage.tech. |
| **09:40:07** | Horizon | Successful authentication using admin credentials from IP 134.209.71.220. |
| **09:40:29** | Horizon | Download of admin-openrc.sh (containing project IDs and API secrets). |

| Timestamp | Service | Event / Action Description |
|---|---|---|
| **09:41:44** | Keystone | First API call using stolen X-Auth-Token to enumerate cloud resources. |
| **09:45:23** | Swift | **Exfiltration:** Download of user-details.csv (28 PII records). |
| **09:45:47** | Swift | **Exfiltration:** Download of employee-details.csv. |
| **09:48:02** | Keystone | **Persistence:** Creation of new user jellibean via /v3/users POST request. |
| **09:49:15** | Keystone | **Privilege Escalation:** Assigned admin role to jellibean via PUT request. |

## 4. Technical Investigation & Methodology




### 4.1 Analysis Summary

The attack followed a structured path from initial reconnaissance to full data exfiltration and account persistence within the OpenStack environment.

- **Subdomain Enumeration (Reconnaissance):**
  - Between 09:38 and 09:40 UTC, the attacker used the tool **ffuf** to perform automated fuzzing of subdomains.
  - The attacker tested unique subdomains,and eventually discovering cloud.vantage.tech, which hosted the OpenStack Horizon dashboard.
- **Credential Brute-Force (Initial Access):**

- Three failed login attempts were made using common credentials (admin/admin, demo/demo, root/root).
- At 09:40:07 UTC, the attacker successfully logged in with the credentials admin / StrongAdminSecret.

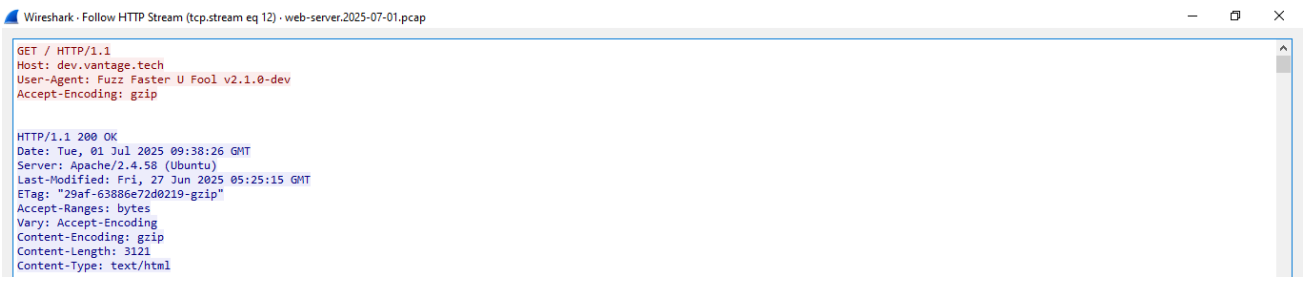
- **Pivot Artifact Download:**
  - At 09:40:29 UTC, the attacker downloaded the **OpenRC file** (admin-openrc.sh) from the dashboard.
  - This file contained the internal API authentication URL and project details, allowing the attacker to bypass the web interface and interact directly with the OpenStack controller.
- **Internal Discovery and Data Exfiltration:**
  - The attacker discovered three containers (dev-files, employee-data, and user-data) and exfiltrated sensitive data.
  - At 09:45:23 UTC, they downloaded user-details.csv containing 28 PII records, followed by employee-details.csv shortly after.
- **Account Persistence:**
  - To maintain access, the attacker created a backdoor user named jellibean with the password P@$$word at 09:48:02 UTC.
  - At 09:49:15 UTC, the attacker granted the jellibean user the **admin role** on the project, ensuring high-level persistent access.

## 5. Attacker Behavior Mapping (Cyber Kill Chain)

### 5.1. Reconnaissance

The attacker began by gathering information about the target's infrastructure to identify potential entry points.

- The attacker fuzzed the web server to discover hidden resources. The Tool Used was **ffuf v2.1.0** (Fuzz Faster U Fool).




- The attacker discovered the **"cloud"** subdomain (cloud.vantage.tech).

Wireshark · Follow HTTP Stream (tcp.stream eq 206) · web-server.2025-07-01.pcap

```
GET / HTTP/1.1
Host: cloud.vantage.tech
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
Sec-Purpose: prefetch;prerender
Purpose: prefetch
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: en-GB,en-US;q=0.9,en;q=0.8,es;q=0.7
Cookie: login_region=default; login_domain=""; csrftoken=zbyL3KweavrXPtJkg6ES943ak9z1eLcW


HTTP/1.1 302 Found
Date: Tue, 01 Jul 2025 09:39:07 GMT
Server: Apache/2.4.58 (Ubuntu)
Location: http://cloud.vantage.tech/dashboard/
Content-Length: 304
Content-Type: text/html; charset=iso-8859-1
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>302 Found</title>
</head><body>
<h1>Found</h1>
<p>The document has moved <a href="http://cloud.vantage.tech/dashboard/">here</a>.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at cloud.vantage.tech Port 80</address>
</body></html>
```

### 5.2. Weaponization & Delivery

- The "Weaponization & delivery" in this scenario was selection of the cloud dashboard as the primary target.
- Attacker targeted login portal at http://cloud.vantage.tech/dashboard/auth/login/

### 5.4. Exploitation

The attacker attempted to gain unauthorized access to the dashboard through credential-based attacks.

- They successfully logged into the OpenStack Horizon dashboard using the credentials admin : StrongAdminSecret at **09:40:07 UTC**, then the attacker got **administrative access** to the web interface.

web-server.2025-07-01.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

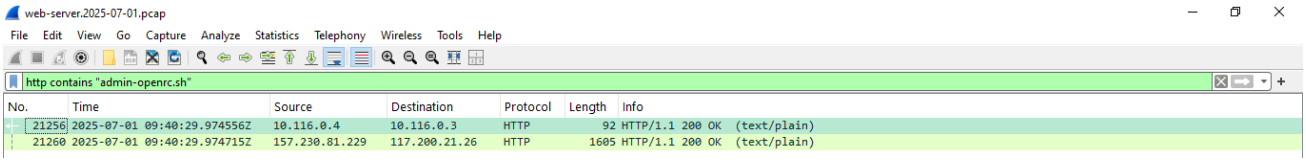
ip.dst == 117.200.21.26 && http.response.code == 302

| No. | Time | Source | Destination | Protocol | Lengt | Info |
|---|---|---|---|---|---|---|
| 2379 | 2025-07-01 09:38:37.46677… | 157.230.81.229 | 117.200.21.26 | HTTP | 581 | HTTP/1.1 302 Found (text/html) |
| 20671 | 2025-07-01 09:39:07.54774… | 157.230.81.229 | 117.200.21.26 | HTTP | 637 | HTTP/1.1 302 Found (text/html) |
| 20687 | 2025-07-01 09:39:07.81972… | 157.230.81.229 | 117.200.21.26 | HTTP | 431 | HTTP/1.1 302 Found |
| 21107 | 2025-07-01 09:40:07.75229… | 157.230.81.229 | 117.200.21.26 | HTTP | 903 | HTTP/1.1 302 Found |
| 21123 | 2025-07-01 09:40:08.03984… | 157.230.81.229 | 117.200.21.26 | HTTP | 527 | HTTP/1.1 302 Found |

### 5.5. Installation

Once inside the dashboard, the attacker moved to extract sensitive configuration data to deepen their access.

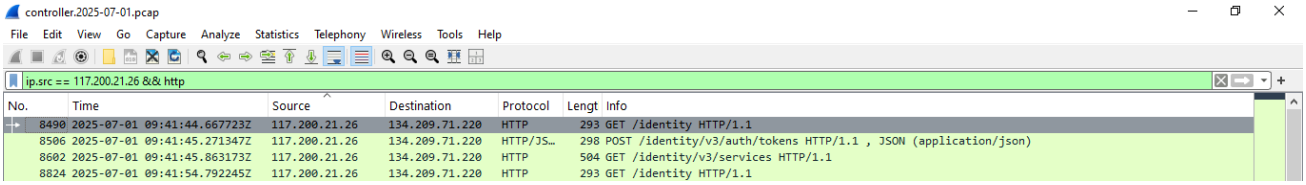
- The attacker downloaded an OpenStack API remote access config file named **admin-openrc.sh** on **2025-07-01 at 09:40:29 UTC** through navigated to the **Project > API Access** section of the dashboard. This file contained the credentials necessary to interact directly with the OpenStack API.



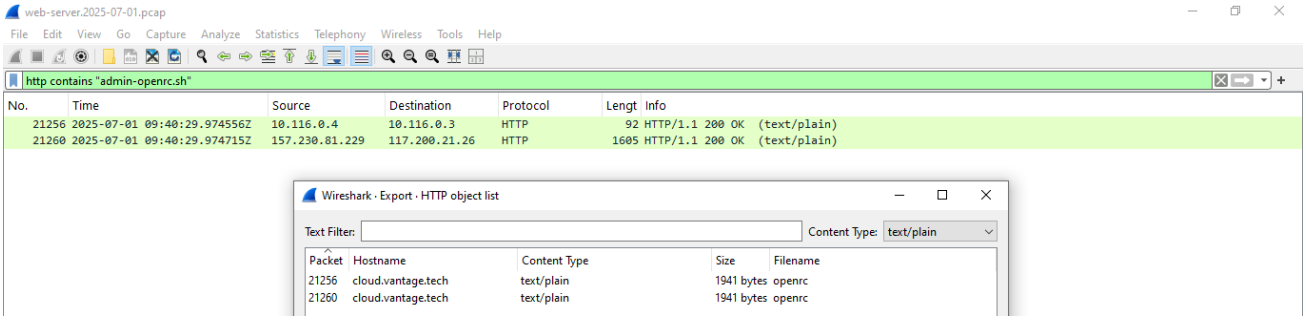

## 5.6. Command & Control (C2)

Using the stolen API credentials, the attacker began interacting directly with the controller node's API.

- First API interaction occurred at **09:41:44 UTC**.




- The attacker downloaded "OpenStack RC" file.




- The attacker identified the default ***Project ID*** (9fb84977ff7c4a0baf0d5dbb57e235c7) from downloaded "OpenStack RC" file.
- OpenStack API requests for the **Swift** storage service requires the Project ID to be part of the endpoint URL. Attacker used the Project ID 9fb84977ff7c4a0baf0d5dbb57e235c7 mentioned in "OpenStack RC" file to access the specific storage location where sensitive data was kept (http://134.209.71.220:8080/v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7).

***<u>openrc file</u>***

openrc - Notepad

File Edit Format View Help

```
#!/usr/bin/env bash
# To use an OpenStack cloud you need to authenticate against the Identity
# service named keystone, which returns a **Token** and **Service Catalog**.
# The catalog contains the endpoints for all services the user/tenant has
# access to - such as Compute, Image Service, Identity, Object Storage, Block
# Storage, and Networking (code-named nova, glance, keystone, swift,
# cinder, and neutron).
# *NOTE*: Using the 3 *Identity API* does not necessarily mean any other
# OpenStack API is version 3. For example, your cloud provider may implement
# Image API v1.1, Block Storage API v2, and Compute API v2.0. OS_AUTH_URL is
# only for the Identity API served through keystone.
export OS_AUTH_URL=http://134.209.71.220/identity
# With the addition of Keystone we have standardized on the term **project**
# as the entity that owns the resources.
export OS_PROJECT_ID=9fb84977ff7c4a0baf0d5dbb57e235c7
export OS_PROJECT_NAME="admin"
export OS_USER_DOMAIN_NAME="Default"
if [ -z "$OS_USER_DOMAIN_NAME" ]; then unset OS_USER_DOMAIN_NAME; fi
export OS_PROJECT_DOMAIN_ID="default"
if [ -z "$OS_PROJECT_DOMAIN_ID" ]; then unset OS_PROJECT_DOMAIN_ID; fi
# unset v2.0 items in case set
unset OS_TENANT_ID
unset OS_TENANT_NAME
# In addition to the owning entity (tenant), OpenStack stores the entity
# performing the action as the **user**.
export OS_USERNAME="admin"
# With Keystone you pass the keystone password.
echo "Please enter your OpenStack Password for project $OS_PROJECT_NAME as user $OS_USERNAME: "
read -sr OS_PASSWORD_INPUT
export OS_PASSWORD=$OS_PASSWORD_INPUT
# If your configuration has multiple regions, we set that information here.
# OS_REGION_NAME is optional and only valid in certain environments.
export OS_REGION_NAME="RegionOne"
# Don't leave a blank variable, unset it if it was empty
if [ -z "$OS_REGION_NAME" ]; then unset OS_REGION_NAME; fi
export OS_INTERFACE=public
export OS_IDENTITY_API_VERSION=3
```

## 5.7. Actions on Objectives

Exfiltration of customer PII and creation of a persistent backdoor account.

### *5.7.1. Exfiltration*

The primary goal of the attacker was the theft of sensitive company data.

#### *A. Discovering storage containers*

– The attacker discovered three storage containers: **dev-files**, **employee-data**, and **user-data**.

controller.2025-07-01.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.uri contains "/v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7"

| No. | Time | Source | Destination | Protocol | Lengt | Info |
|---|---|---|---|---|---|---|
| 12892 | 2025-07-01 09:43:27.279520Z | 117.200.21.26 | 134.209.71.220 | HTTP | 528 | GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7?format=json HTTP/1.1 |
| 13367 | 2025-07-01 09:43:27.585909Z | 134.209.71.220 | 117.200.21.26 | HTTP/JSON | 1031 | HTTP/1.1 200 OK , JSON (application/json) |
| 13907 | 2025-07-01 09:43:47.205294Z | 117.200.21.26 | 134.209.71.220 | HTTP | 538 | GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/user-data?format=json HTTP/1.1 |
| 14028 | 2025-07-01 09:43:47.275262Z | 134.209.71.220 | 117.200.21.26 | HTTP/JSON | 713 | HTTP/1.1 200 OK , JSON (application/json) |
| 14522 | 2025-07-01 09:44:05.848571Z | 117.200.21.26 | 134.209.71.220 | HTTP | 542 | GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/employee-data?format=json HTTP/1.1 |
| 14651 | 2025-07-01 09:44:05.928218Z | 134.209.71.220 | 117.200.21.26 | HTTP/JSON | 717 | HTTP/1.1 200 OK , JSON (application/json) |
| 16398 | 2025-07-01 09:45:23.060797Z | 117.200.21.26 | 134.209.71.220 | HTTP | 543 | GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/user-data/user-details.csv HTTP/1.1 |
| 16529 | 2025-07-01 09:45:23.133769Z | 134.209.71.220 | 117.200.21.26 | HTTP | 1812 | HTTP/1.1 200 OK (text/csv) |
| 17139 | 2025-07-01 09:45:47.435106Z | 117.200.21.26 | 134.209.71.220 | HTTP | 551 | GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/employee-data/employee-details.csv HTTP/1.1 |
| 17259 | 2025-07-01 09:45:47.476812Z | 134.209.71.220 | 117.200.21.26 | HTTP | 420 | HTTP/1.1 200 OK (text/csv) |


```
[{"name": "dev-files", "count": 0, "bytes": 0, "last_modified": "2025-07-01T04:22:36.008860", "storage_policy": "Policy-0"}, {"name": "employee-data", "count": 0, "bytes": 0, "last_modified"
: "2025-07-01T04:22:28.334080", "storage_policy": "Policy-0"}, {"name": "user-data", "count": 0, "bytes": 0, "last_modified": "2025-07-01T04:22:07.707130", "storage_policy": "Policy-0"}]
```


#### *B. Data Exfiltration*

controller.2025-07-01.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.uri contains "csv"

| No. | Time | Source | Destination | Protocol | Lengt | Info |
|---|---|---|---|---|---|---|
| 16398 | 2025-07-01 09:45:23.060797Z | 117.200.21.26 | 134.209.71.220 | HTTP | 543 | GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/user-data/user-details.csv HTTP/1.1 |
| 16522 | 2025-07-01 09:45:23.117129Z | 127.0.0.1 | 127.0.0.1 | HTTP | 1402 | GET /sdb1/440/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/user-data/user-details.csv HTTP/1.1 |
| 16524 | 2025-07-01 09:45:23.130632Z | 127.0.0.1 | 127.0.0.1 | HTTP | 1809 | HTTP/1.1 200 OK (text/csv) |
| 16529 | 2025-07-01 09:45:23.133769Z | 134.209.71.220 | 117.200.21.26 | HTTP | 1812 | HTTP/1.1 200 OK (text/csv) |
| 17139 | 2025-07-01 09:45:47.435106Z | 117.200.21.26 | 134.209.71.220 | HTTP | 551 | GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/employee-data/employee-details.csv HTTP/1.1 |
| 17251 | 2025-07-01 09:45:47.470803Z | 127.0.0.1 | 127.0.0.1 | HTTP | 1418 | GET /sdb1/298/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/employee-data/employee-details.csv HTTP/1.1 |
| 17253 | 2025-07-01 09:45:47.474114Z | 127.0.0.1 | 127.0.0.1 | HTTP | 3297 | HTTP/1.1 200 OK (text/csv) |
| 17259 | 2025-07-01 09:45:47.476812Z | 134.209.71.220 | 117.200.21.26 | HTTP | 420 | HTTP/1.1 200 OK (text/csv) |

- The attacker downloaded the sensitive file **user-details.csv** at **09:45:23 UTC**. The exfiltrated file contained 28 user records, including full names, emails, and phone numbers.

Wireshark · Follow HTTP Stream (tcp.stream eq 600) · controller.2025-07-01.pcap

```
GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/user-data/user-details.csv HTTP/1.1
Host: 134.209.71.220:8080
User-Agent: openstacksdk/4.6.0 keystoneauth1/5.11.1 python-requests/2.32.4 CPython/3.13.5
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
X-Auth-Token: gAAAAABoY64yBlAoWptNO2O80tQGgeAMtriIUtNhdstpOonTLJTZ9Ow5ZtLpDQR-CgR1TgYpISv39E9MSfPUW56v5-gIxLDQd9gFCU4ggquhZX_u7APaa-i9jfdiDpw4iJdwo3uNp-ankyXXU6wsuqSb-1nb5c4G3AUIg9sCA7CxtC
mShPXZD8M


HTTP/1.1 200 OK
Content-Type: text/csv
Etag: 2197a57085557424cefc95f85efb7499
Last-Modified: Tue, 01 Jul 2025 04:31:31 GMT
X-Timestamp: 1751344290.17360
Accept-Ranges: bytes
Content-Length: 1367
X-Trans-Id: tx89c3d915d2c64b1c8cda1-006863ae33
X-Openstack-Request-Id: tx89c3d915d2c64b1c8cda1-006863ae33
Date: Tue, 01 Jul 2025 09:45:23 GMT
Connection: keep-alive

Full Name,Email,Phone Number
John Doe,john.doe@example.com,(123) 456-7890
Jane Smith,jane.smith@example.com,(234) 567-8901
Alice Johnson,a.johnson@example.com,(345) 678-9012
Bob Brown,b.brown@example.com,(456) 789-0123
Charlie Davis,c.davis@example.com,(567) 890-1234
Diana Wilson,d.wilson@example.com,(678) 901-2345
Ethan Moore,e.moore@example.com,(789) 012-3456
Fiona Taylor,f.taylor@example.com,(890) 123-4567
George Wilson,g.wilson@example.com,(901) 234-5678
Helen Adams,h.adams@example.com,(012) 345-6789
Ian Lee,i.lee@example.com,(123) 456-7890
Julia Smith,j.smith@example.com,(234) 567-8901
Kevin Miller,k.miller@example.com,(345) 678-9012
Laura Evans,l.evans@example.com,(456) 789-0123
Michael Thomas,m.thomas@example.com,(567) 890-1234
```

- The attacker downloaded the sensitive file **employee-details.csv** at **09:45:47 UTC**. The exfiltrated file contained 50 employee records, including ID, Full Name, Email, Department

Wireshark · Follow HTTP Stream (tcp.stream eq 628) · controller.2025-07-01.pcap

```
GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/employee-data/employee-details.csv HTTP/1.1
Host: 134.209.71.220:8080
User-Agent: openstacksdk/4.6.0 keystoneauth1/5.11.1 python-requests/2.32.4 CPython/3.13.5
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
X-Auth-Token: gAAAAABoY65KvXpV8oA0UUQgE0J_8KHhEG5VjVwYVqUPhVFRGVJkLi470SpJCKWQwiHFfPzsk_3xVWXS3duowo_SHB79tuxCQ0TdMuT68rgxFcVmyF3OEzmEzXF87P2d27vMuhy7BrghAxU0FXUiHijr9ZumkKF8pfZTAHG-fEvWc1
cUyiuinbE


HTTP/1.1 200 OK
Content-Type: text/csv
Etag: 4a1f84a086173a6e82fd87e4e45d82e6
Last-Modified: Tue, 01 Jul 2025 04:32:00 GMT
X-Timestamp: 1751344319.32461
Accept-Ranges: bytes
Content-Length: 2855
X-Trans-Id: tx98a3eed00e8a4448addaa-006863ae4b
X-Openstack-Request-Id: tx98a3eed00e8a4448addaa-006863ae4b
Date: Tue, 01 Jul 2025 09:45:47 GMT
Connection: keep-alive

ID,Full Name,Email,Department
1001,John Doe,john.doe@techcompany.com,Software Development
1002,Jane Smith,jane.smith@techcompany.com,Product Management
1003,Michael Johnson,michael.johnson@techcompany.com,DevOps
1004,Emily Davis,emily.davis@techcompany.com,IT Support
1005,David Wilson,david.wilson@techcompany.com,Cybersecurity
1006,Sarah Lee,sarah.lee@techcompany.com,Data Science
1007,James Wilson,james.wilson@techcompany.com,UX Design
1008,Michael Chen,micah.chen@techcompany.com,Cloud Engineering
1009,Emma Taylor,emma.taylor@techcompany.com,Network Security
1010,David Kim,david.kim@techcompany.com,QA Testing
1011,Olivia Brown,olivia.brown@techcompany.com,Marketing
1012,Andrew Lee,andrew.lee@techcompany.com,HR
1013,Elizabeth Garcia,elizabeth.garcia@techcompany.com,Finance
1014,William Chen,william.chen@techcompany.com,Engineering
1015,Sophia Kim,sophia.kim@techcompany.com,Product Design
```

### *5.7.2. Persistence*

To ensure continued access even if the initial compromised credentials were changed, the attacker modified the environment.

- The attacker issued a POST request to /identity/v3/users to create a **new user with admin privileges** for persistence.

controller.2025-07-01.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.uri contains "/identity/v3/users"

| No. | Time | Source | Destination | Protocol | Lengt | Info |
|---|---|---|---|---|---|---|
| 10097 | 2025-07-01 09:42:11.879664Z | 117.200.21.26 | 134.209.71.220 | HTTP | 501 | GET /identity/v3/users HTTP/1.1 |
| 16398 | *REF* | 117.200.21.26 | 134.209.71.220 | HTTP | 543 | GET /v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7/user-data/user-details.csv HTTP/1.1 |
| 20776 | 2025-07-01 09:48:02.472070Z | 117.200.21.26 | 134.209.71.220 | HTTP/JSON | 202 | POST /identity/v3/users HTTP/1.1 , JSON (application/json) |
| 22694 | 2025-07-01 09:49:12.039163Z | 117.200.21.26 | 134.209.71.220 | HTTP | 498 | GET /identity/v3/users/jellibean HTTP/1.1 |
| 22774 | 2025-07-01 09:49:12.653825Z | 117.200.21.26 | 134.209.71.220 | HTTP | 516 | GET /identity/v3/users?name=jellibean HTTP/1.1 |
| 23563 | 2025-07-01 09:49:22.831223Z | 117.200.21.26 | 134.209.71.220 | HTTP | 501 | GET /identity/v3/users HTTP/1.1 |
| 4204 | 2025-07-01 09:40:07.547696Z | 134.209.71.220 | 134.209.71.220 | HTTP | 518 | GET /identity/v3/users/b1cbe2fc995a47ae85a4408a52aeca38/projects HTTP/1.1 |
| 4325 | 2025-07-01 09:40:07.638492Z | 134.209.71.220 | 134.209.71.220 | HTTP/JSON | 1093 | HTTP/1.1 200 OK , JSON (application/json) |
| 5919 | 2025-07-01 09:40:10.224120Z | 134.209.71.220 | 134.209.71.220 | HTTP | 466 | GET /identity/v3/users/b1cbe2fc995a47ae85a4408a52aeca38/projects HTTP/1.1 |
| 5939 | 2025-07-01 09:40:10.235830Z | 134.209.71.220 | 134.209.71.220 | HTTP/JSON | 1093 | HTTP/1.1 200 OK , JSON (application/json) |
| 6187 | 2025-07-01 09:40:14.512720Z | 134.209.71.220 | 134.209.71.220 | HTTP | 466 | GET /identity/v3/users/b1cbe2fc995a47ae85a4408a52aeca38/projects HTTP/1.1 |
| 6209 | 2025-07-01 09:40:14.524603Z | 134.209.71.220 | 134.209.71.220 | HTTP/JSON | 1093 | HTTP/1.1 200 OK , JSON (application/json) |
| 6385 | 2025-07-01 09:40:19.924521Z | 134.209.71.220 | 134.209.71.220 | HTTP | 466 | GET /identity/v3/users/b1cbe2fc995a47ae85a4408a52aeca38/projects HTTP/1.1 |
| 6411 | 2025-07-01 09:40:19.935692Z | 134.209.71.220 | 134.209.71.220 | HTTP/JSON | 1093 | HTTP/1.1 200 OK , JSON (application/json) |
| 6542 | 2025-07-01 09:40:20.583547Z | 134.209.71.220 | 134.209.71.220 | HTTP | 466 | GET /identity/v3/users/b1cbe2fc995a47ae85a4408a52aeca38/projects HTTP/1.1 |
| 6564 | 2025-07-01 09:40:20.592436Z | 134.209.71.220 | 134.209.71.220 | HTTP/JSON | 1093 | HTTP/1.1 200 OK , JSON (application/json) |
| 6796 | 2025-07-01 09:40:29.963519Z | 134.209.71.220 | 134.209.71.220 | HTTP | 466 | GET /identity/v3/users/b1cbe2fc995a47ae85a4408a52aeca38/projects HTTP/1.1 |
| 6828 | 2025-07-01 09:40:29.971042Z | 134.209.71.220 | 134.209.71.220 | HTTP/JSON | 1093 | HTTP/1.1 200 OK , JSON (application/json) |
| 10180 | 2025-07-01 09:42:11.941388Z | 134.209.71.220 | 117.200.21.26 | HTTP/JSON | 2616 | HTTP/1.1 200 OK , JSON (application/json) |
| 20839 | 2025-07-01 09:48:02.522463Z | 134.209.71.220 | 117.200.21.26 | HTTP/JSON | 635 | HTTP/1.1 201 CREATED , JSON (application/json) |
| 22752 | 2025-07-01 09:49:12.067143Z | 134.209.71.220 | 117.200.21.26 | HTTP/JSON | 411 | HTTP/1.1 404 NOT FOUND , JSON (application/json) |
| 22833 | 2025-07-01 09:49:12.726833Z | 134.209.71.220 | 117.200.21.26 | HTTP/JSON | 742 | HTTP/1.1 200 OK , JSON (application/json) |
| 23640 | 2025-07-01 09:49:22.879169Z | 134.209.71.220 | 117.200.21.26 | HTTP/JSON | 2919 | HTTP/1.1 200 OK , JSON (application/json) |

Wireshark · Follow HTTP Stream (tcp.stream eq 742) · controller.2025-07-01.pcap

```
POST /identity/v3/users HTTP/1.1
Host: 134.209.71.220
User-Agent: openstacksdk/4.6.0 keystoneauth1/5.11.1 python-requests/2.32.4 CPython/3.13.5
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
X-Auth-Token: gAAAAABoY67QSl3AarKC9p_FCUhm-zdlkNPcgfqpHncXtnKqPhHgH79XnHa-4IrDf4WlL8QpLiKIQOE8C4kq3Tv21nkTpzMAuGXwLZkEeexqQlLfUtyrhmGjKsFvflRlIEZb0A-1oQZLVzdk1021QkPqjVjFonIEIEBgH0oZll7xE2hp
7Scnm2o
Content-Type: application/json
Content-Length: 130

{"user": {"password": "P@$$word", "enabled": true, "default_project_id": "9fb84977ff7c4a0baf0d5dbb57e235c7", "name": "jellibean"}}
HTTP/1.1 201 CREATED
Date: Tue, 01 Jul 2025 09:48:02 GMT
Server: Apache/2.4.58 (Ubuntu)
Content-Type: application/json
Content-Length: 312
Vary: X-Auth-Token
x-openstack-request-id: req-70234e40-c6b0-4192-b478-e5cd3732d419
Connection: close

{"user": {"id": "c373da67a62b48f393c45dc071fa80b8", "name": "jellibean", "domain_id": "default", "enabled": true, "default_project_id": "9fb84977ff7c4a0baf0d5dbb57e235c7", "password_expires_
at": null, "options": {}, "links": {"self": "http://134.209.71.220/identity/v3/users/c373da67a62b48f393c45dc071fa80b8"}}}
```

## 6. Indicators of compromise (IOC)

- **IP Address:** 134.209.71.220
- **User-Agent:** ffuf/2.1.0
- **Token Indicator:** X-Auth-Token usage
- **Sensitive File Exfiltration:** user-data.csv
- **Username Created:** jellibean
- **Password:** P@$$word

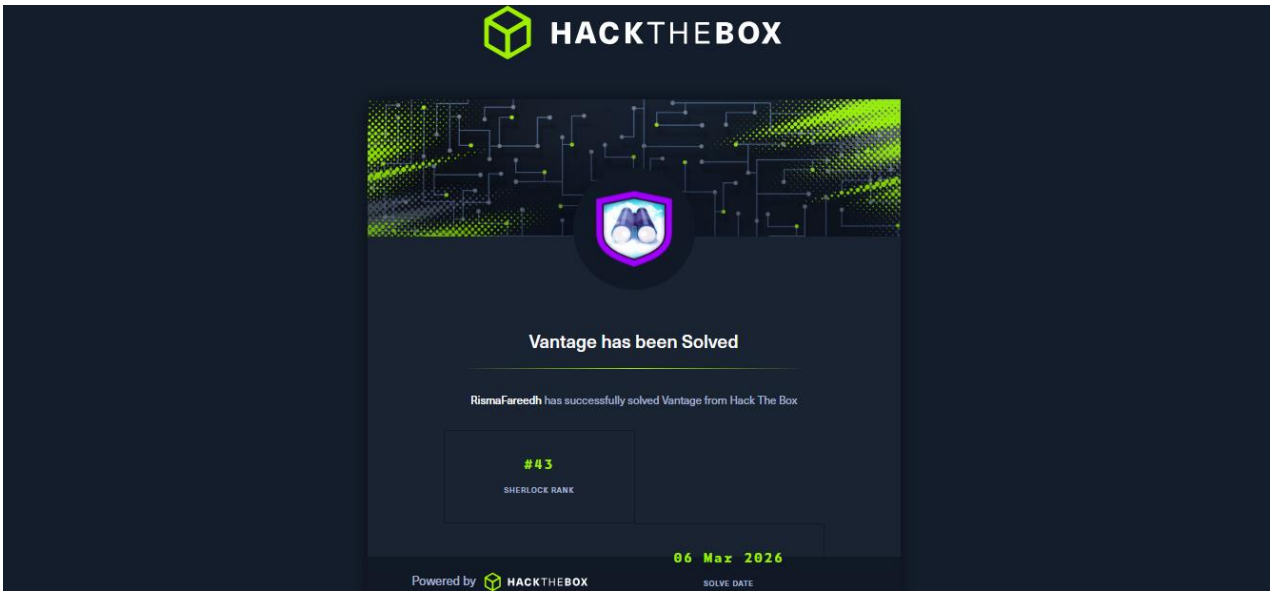
## 7. Recommendations & Remediation

1. **Identity Management:** Implement Multi-Factor Authentication (MFA) for the cloud dashboard and OpenStack API access.

2. **Secret Management:** Rotate all API credentials stored in .sh or config files and transition to a secure vault-based system.

3. **Logging & Monitoring:** Implement real-time alerting for the creation of new administrative users via the Keystone API.

4. **Network Segmentation:** Restrict access to the OpenStack API to known internal IP ranges or via a secure VPN.




https://labs.hackthebox.com/achievement/sherlock/2413013/1162